

Where AI Helps and Where Humans Must Decide: Drawing the Line in Security Operations

Security teams today are drowning in alerts. A mid-sized company can generate thousands of security events a day, and no human team can look at all of them carefully. This is exactly the kind of problem AI is good at: fast pattern matching across huge volumes of data. But there is an important difference between an AI system that gathers information and helps a human think, and an AI system that gets to decide what actually happens next. The first is assistance. The second is authority, and authority in security operations carries real consequences: a wrongly isolated server can halt a business, a wrongly revoked account can lock out an employee at the worst possible moment, and a wrong public statement about a breach can create legal exposure that lasts years. This paper argues that AI should be trusted to inform decisions but not to make the final call on anything irreversible, high-impact, or legally sensitive, and lays out three zones: where AI assistance genuinely helps, decisions AI must never make on its own, and actions that require mandatory human sign-off before they happen.

Part 1: Where AI Assistance Adds Value

The clearest case for AI in security operations is alert triage. A security operations center might receive tens of thousands of raw alerts a week, most of them noise. AI can cluster near-duplicate alerts, score them by likely severity, and rank them so a human analyst spends their limited time on the handful that actually matter. The AI is not deciding anything here; it is doing the sorting work that used to eat up an analyst's whole shift.

Threat intelligence enrichment is another strong fit. When an alert fires, an AI system can automatically look up the IP address or file hash against reputation databases, pull in context about known malware families, and check whether the same indicator has shown up elsewhere in the network. This used to be manual work: an analyst opening five different browser tabs to check five different services. Letting AI do this automatically does not change what happens to the system, it just gets useful context in front of the human faster.

Related-event correlation follows the same logic. If a suspicious login on one server is followed two hours later by an unusual file access on a completely different machine, a human analyst might never connect the two events manually, especially across a large environment. AI is genuinely good at finding these threads across large volumes of logs and presenting them as a single storyline.

AI is also useful for drafting. After an incident, someone has to write up what happened, when, and what was done about it. AI can produce a first draft of an incident summary or a proposed remediation plan, which a human then edits and approves. This saves time without removing the human from the judgment part of the process.

Across all of these examples, the common thread is that the AI is producing information, context, or a first draft, never triggering an action against a live system, a person's access, or a company's public position. That distinction is the boundary this paper is built around.

Part 2: Decisions AI Must Never Make Autonomously

Some decisions should never be left to an AI system operating alone, regardless of how confident its model is. The first category is irreversible, high-impact actions: permanently deleting data, wiping a device, or shutting down a production system that customers depend on. Even if an AI is right nineteen times out of twenty, the one time it is wrong on an irreversible action can be catastrophic, and there is no way to undo it after the fact.

The second category is anything with legal, HR, or compliance consequences. Deciding that an employee is an insider threat, or that an account should be terminated as part of a disciplinary action, touches

someone's livelihood and involves legal exposure for the company. This is a judgment call about a person, not a technical judgment about a system, and it needs a human who can be held accountable for it.

The third category is attribution with real-world consequences, such as declaring that a specific group or nation-state was behind an attack. Attribution claims can trigger diplomatic incidents, lawsuits, or public statements that a company cannot walk back easily. AI enrichment can suggest that indicators overlap with a known campaign, but the final attribution claim, if one is made at all, has to come from a human who understands the wider consequences.

The fourth category is novel or ambiguous situations that fall outside what the AI model has seen before. Confidence scores from AI models are only as good as their training data, and in genuinely new situations those scores become unreliable in ways that are hard to detect from the outside. When a situation looks unprecedented, that itself is a signal that a human needs to be making the call, not the AI.

Part 3: Categories Requiring Mandatory Human Approval Before Execution

Between full AI autonomy and AI staying completely out of the loop, there is a middle category: actions the AI can prepare or recommend, but cannot execute without a human approving first. Incident containment actions with business impact belong here. Isolating a production server, blocking a network segment, or killing a customer-facing service can stop an attack, but it can also cause an outage if the AI's judgment is wrong. These actions should be proposed by the AI and executed only after human clicks approve.

Access revocation is another approval-gated category, especially for high-privilege or executive accounts, where a mistaken lockout can cause serious disruption or where the account itself might be more sensitive than the alert suggests. Any external communication also belongs here: notifying customers, regulators, or law enforcement about a breach is a decision with legal and reputational weight that should always go through a human, typically alongside legal counsel.

Not every action needs the same level of approval, though. A sensible design allows very low-risk, high-confidence, easily reversible actions, such as automatically enriching an alert with threat intelligence, to proceed without approval, while raising the bar sharply for anything with real-world impact.

Conclusion

AI belongs in the front half of the security workflow: triage, enrichment, correlation, and drafting, where speed and scale genuinely help and mistakes are cheap to correct. Humans belong in the back half: any decision that is irreversible, affects a person's job or rights, touches legal or regulatory obligations, or involves attributing an attack to a real-world actor. A practical way to organize this is a three-tier model. Tier one covers research and enrichment actions that AI can take on its own because they do not change anything. Tier two covers containment and access actions that AI can prepare but a human must approve before execution. Tier three covers attribution, HR and legal matters, and novel situations, which should always be decided by a human, with AI providing supporting analysis only. This division lets security teams use AI's speed without giving up the accountability that only a human can carry.

AI Assistance Note

I used Claude as an AI assistant for this assignment. For Task 1, I used it to draft the position paper based on the assignment's required structure (AI-assistance value, decisions AI must never make, mandatory human-approval categories, and conclusion); I reviewed the content and reasoning myself. For Task 2, I used it to help design the JSON Schema structure and required fields for the five sections, and to explain the reasoning behind specific design choices (e.g., the conditional approval-field logic). For Task 3, I used it to help write and debug the Python validator, including the sample records and error-reporting logic, and verified that it runs correctly against the schema.